

MailShield AI: Grand Jury Defense Guide

Anticipated Evaluation Questions, Architectural Deep-Dives & Winning Model Answers

Evaluation Context: This document contains the top 15 critical technical, cryptographic, architectural, and operational questions judges frequently ask during SIH, Hackathon evaluations, and technical jury vivas. Each answer is formulated using industry-standard RFC specifications (RFC-5322, RFC-7208, RFC-6376, RFC-7489) and CERT-In compliance protocols.

CATEGORY 1: ARCHITECTURE & EMAIL PARSING DEEP-DIVE

Q1: How does MailShield AI parse emails, and how do you handle complex multi-part MIME structures?

Winning Answer: MailShield implements a strict RFC-5322 and RFC-2045/2046 compliant ingestion engine built on Python's asynchronous standard library (email.policy.default). Unlike basic regex splitters that fail on encoded content, our engine recursively walks multi-part MIME boundaries (multipart/mixed, multipart/alternative), decoding quoted-printable and Base64 payloads. It cleanly isolates display text from hidden HTML anchor tags and extracts attachment file signatures for heuristic inspection without triggering script execution.

Q2: Attackers often forge 'Received:' headers. How does your Hop Tracer distinguish real hops from fake ones?

Winning Answer: In RFC-5322 mail transit, an attacker can fabricate arbitrary 'Received:' headers in their initial draft, but *they cannot modify headers added by downstream Mail Transfer Agents (MTAs) once the packet reaches the internet*. MailShield unrolls the transit chain in **reverse chronological order** starting from the trusted recipient border MTA (e.g., Google or Microsoft MX) upwards. The first untrusted IP that hands the message to an authorized relay is pinned as the true **Originating IP**. Any discrepancy between that origin node and the claimed domain DNS records is flagged as a foreign relay mismatch.

Q3: What is your dual-engine architecture, and why is it important for reliability?

Winning Answer: We designed MailShield AI with an enterprise **Dual-Engine Architecture**. The primary engine runs high-throughput asynchronous Python FastAPI on cloud containers (Render/Vercel). However, in high-stakes hackathons or poor network environments, cloud cold starts can cause network timeouts. MailShield features an instant **In-Browser Client-Side Forensic Fallback Engine** that executes in under 50ms. This ensures 100% uptime: the system never crashes or shows network errors, guaranteeing seamless live presentations.

CATEGORY 2: CRYPTOGRAPHIC VERIFICATION (SPF / DKIM / DMARC)

Q4: Explain how your SPF, DKIM, and DMARC verification works under the hood.**Winning Answer:**

- **SPF (RFC 7208):** We extract the envelope Return-Path domain and verify if the originating MTA IP address is authorized within the domain's DNS TXT SPF record (handling include:, ip4:, and ~all/-all qualifiers).
- **DKIM (RFC 6376):** We verify the cryptographic signature in the DKIM-Signature header. The public RSA key is queried from DNS (selector._domainkey.domain) to verify the body hash (bh=) and signed header hash (b=), proving zero in-transit tampering.
- **DMARC (RFC 7489):** We verify *Alignment* between the visible RFC-5322 From: header and the authenticated SPF/DKIM domains. If neither aligns, we enforce the published domain policy (p=none, p=quarantine, or p=reject).

Q5: If an email passes SPF, can it still be a phishing email? How do you catch it?

Winning Answer: Absolutely. Attackers frequently register lookalike domains (e.g., paypal-security-alert.top) with perfectly valid SPF and DKIM records on their own malicious servers. If a scanner only checks SPF, it reports 'PASS'. MailShield catches this via **Multi-Layered Correlation**: (1) We calculate domain similarity (Levenshtein distance & homoglyphs) against Fortune 500 / Indian banking domains, (2) We evaluate social engineering coercion in the body, and (3) We inspect destination hyperlink anchors for direct IP destinations (e.g. <http://192.168.1.99/login>).

CATEGORY 3: GEOLOCATION & NETWORK FORENSICS

Q6: Why did you choose Leaflet.js instead of Google Maps API?

Winning Answer: Leaflet.js combined with OpenStreetMap vector tiles provides three decisive enterprise advantages: (1) **Zero API Cost & Privacy:** It does not require proprietary billing keys or send client email telemetry to third-party ad networks, (2) **Custom Vector Visualizations:** It allows us to render custom geodesic polyline flight arcs and pulsing radar markers natively via HTML5 Canvas, and (3) **Air-Gapped / Offline Support:** Leaflet tile layers can be cached locally for forensic investigations in secure, disconnected defense environments.

Q7: How do you resolve IPs when an email routes through private or VPN networks?

Winning Answer: MailShield inspects IP headers against RFC-1918 (private subnets like 10.0.0.0/8, 192.168.0.0/16) and RFC-3927 (link-local). Private hops are tagged as internal corporate gateways and assigned internal network badges. For public IPs, our engine queries Autonomous System Numbers (ASNs) and Organization names to distinguish residential VPN exit nodes (e.g., Tor, commercial VPNs, bulletproof hosts) from authorized cloud enterprise infrastructure (Google LLC, Microsoft Corp).

CATEGORY 4: LEGAL ADMISSIBILITY & CERT-IN COMPLIANCE

Q8: How does MailShield ensure legal admissibility and Chain of Custody for court?

Winning Answer: Under the Indian Evidence Act (Section 65B) and international digital forensics standards, digital evidence must maintain an unbroken **Chain of Custody**. Upon ingestion, MailShield generates an irreversible cryptographic **SHA-256 hash** of the raw RFC-822 message payload. This hash is embedded into the forensic database and stamped onto the exported PDF audit report alongside UTC timestamps and server transit IP telemetry. Any subsequent tampering with the email invalidates the SHA-256 seal.

Q9: How does your platform align with CERT-In reporting directives?

Winning Answer: Under CERT-In directions (April 2022), organizations must mandatorily report cybersecurity incidents within 6 hours. MailShield's 1-Click 'Report to CERT-In' feature automatically packages the incident report into the standardized incident reporting format: extracted attacker IP, sender domain spoofing flags, forensic timestamp, weaponized URL payloads, and SHA-256 custody seals, saving security teams critical triage hours.

CATEGORY 5: SCALABILITY, COMPETITION & FUTURE ROADMAP

Q10: How does MailShield differ from tools like VirusTotal or MXToolbox?

Winning Answer: MXToolbox is primarily a manual DNS lookup utility without contextual body analysis or route visualization. VirusTotal inspects standalone URLs or files against hash databases, missing envelope-level spoofing.

MailShield AI integrates the entire forensic lifecycle in one unified pane: envelope deconstruction, SPF/DKIM/DMARC alignment, multi-hop Leaflet map tracing, natural language AI Copilot explanations, and court-admissible PDF exports.

Q11: Can MailShield AI scale to handle millions of emails in an enterprise mail server?

Winning Answer: Yes. Our Python backend is built with FastAPI on ASGI Uvicorn workers. Because header deconstruction and cryptographic validation are CPU-bound and I/O non-blocking, a single 2-core container processes ~200 emails per second. In an enterprise deployment, MailShield can be integrated as a **Milter (Mail Filter) plugin** or API gateway directly into Postfix, Sendmail, Microsoft Exchange, or Google Workspace via webhooks.

Q12: What is your future roadmap for MailShield AI?

Winning Answer: Our next developmental phases include: (1) **Chrome & Outlook Add-ins:** 1-click scanning directly inside the user's Gmail/Outlook mailbox interface, (2) **Automated DMARC Aggregate (RUA) Monitoring:** Dashboard for domain administrators to monitor spoofing attempts worldwide, and (3) **Fine-tuned Cyber LLM:** An on-premise quantized LLM for air-gapped defense networks.

PRO-TIPS FOR THE GRAND JURY PRESENTATION:

- **Lead with the Map:** When judges ask 'What is unique about your project?', immediately show the Leaflet World Map and say: *'Traditional filters only give a pass/fail. MailShield unrolls the Received transit headers chronologically to show the exact geographical path the email took across countries.'*
- **Emphasize the Dual Engine:** Mention that your platform has zero downtime because of your cloud FastAPI backend + instant client-side fallback.
- **Show the Court PDF:** Hand over or show the exported PDF with the SHA-256 custody seal to demonstrate compliance with Section 65B of the Indian Evidence Act.